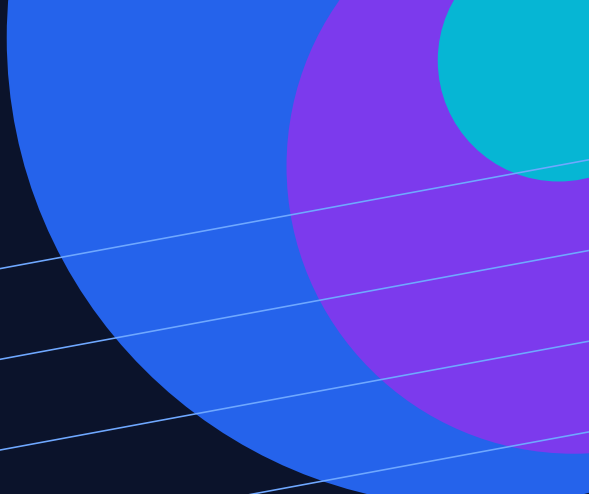




THREAT RESEARCH / DETECTION ENGINEERING

Studio 5000 ACD-Associated Novel File Writes

Baseline-assisted hunt for behavior compatible with CVE-2026-9108

REPORT	STATUS	CONFIDENCE
Threat-hunting dossier	Hunting / validation	Medium

Prepared for defensive research and environment-specific validation. Source facts, analytical interpretation, assumptions and proposed detection logic are intentionally separated.

VERSION 1.0 / 22 JULY 2026

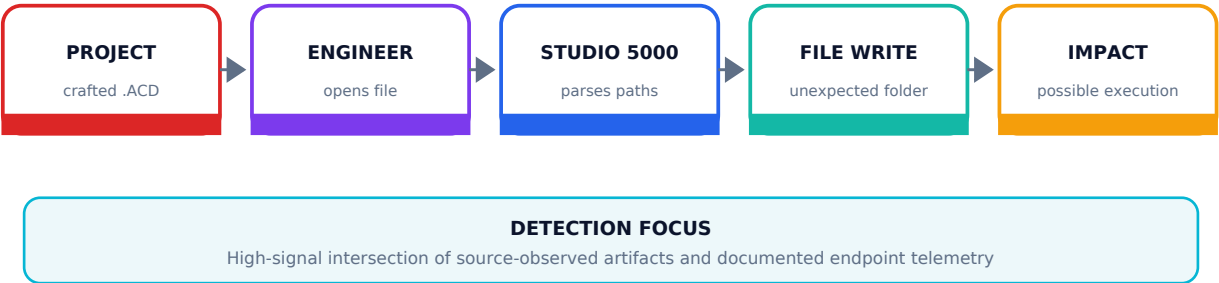
Executive Assessment

WHY THIS MATTERS

CVE-2026-9108 concerns insufficient path restriction in Studio 5000 Logix Designer project handling. A defensible endpoint hypothesis is to correlate recent .ACD activity with Rockwell-attributed writes into folders unseen for that device during a 30-day baseline. This is consequence-oriented hunting, not exploit proof.

Dimension	Assessment	Operational Implication
Observed behavior	Rockwell states that improper path limitation in ACD content may cause writes outside the intended directory when a crafted project is opened.	Endpoint file events may expose the project artifact and subsequent write destinations.
Detection posture	Hunting / validation	Run as validation/hunting until normal Studio 5000 write paths, process metadata and event completeness are measured.
Telemetry	Microsoft Defender XDR DeviceFileEvents	Provides file action, path, origin, initiating process/product and device context.
Primary limitation	DeviceFileEvents cannot prove that Studio 5000 opened the project or that a write resulted from path traversal.	Every match requires endpoint timeline validation and may be benign engineering activity.

Attack and observation flow



Evidence Model

Evidence class	Statement	Use in the package
Source fact	Rockwell describes CVE-2026-9108 as improper limitation of paths within ACD files that may permit path traversal and writes outside the intended location.	Directly supports the selected behavior or artifact.
Documented telemetry	DeviceFileEvents documents file name/path, action, origin URL/referrer/IP, initiating process, company/product metadata, account and hashes.	Supports the table, fields and investigation pivots.
Analytical interpretation	A Rockwell-attributed write into a device folder absent from a prior baseline, near an ACD file event, is compatible with the vulnerability consequence but not unique to exploitation.	Defines why the intersection may be distinguishable.
Unvalidated assumption	Rockwell company/product metadata is populated consistently and the relevant file writes are captured.	Must be measured before deployment or promotion.

EVIDENCE BOUNDARY

No alert generated by this logic should be described as confirmed exploitation. The query cannot inspect embedded ACD paths, prove project opening or establish code execution.

Telemetry contract

Component	Requirement	Failure condition
Data source	Microsoft Defender XDR DeviceFileEvents	MDE unavailable on engineering workstations or DeviceFileEvents incomplete.
Core fields	Timestamp, DeviceId, DeviceName, ActionType, FileName, FolderPath, FileOriginUrl, FileOriginReferrerUrl, FileOriginIP, initiating-process company/product/name/command line/account, SHA1, ReportId	Company/product metadata, path or initiating process not populated.
Time context	30-day baseline excluding the most recent 24 hours; 24-hour detection window; 5 minutes before to 30 minutes after ACD activity.	Retention is shorter than baseline or project-open time is not represented by a file event.

Detection Logic

HYPOTHESIS

If a crafted ACD project causes an out-of-scope write, a recent ACD file event may be followed by a Rockwell-attributed create/modify/rename action in a folder not previously used by that device.

```
let DetectionWindow = 1d;
let BaselineWindow = 30d;
let BaselinePaths = materialize(
  DeviceFileEvents
  | where Timestamp between (ago(BaselineWindow) .. ago(DetectionWindow))
  | where InitiatingProcessVersionInfoCompanyName has "Rockwell"
    or InitiatingProcessVersionInfoProductName has "Studio 5000"
  | extend NormalizedFolder = tolower(FolderPath)
  | summarize by DeviceId, NormalizedFolder
);
let RecentAcd = materialize(
  DeviceFileEvents
  | where Timestamp >= ago(DetectionWindow)
  | where FileName endswith ".acd"
  | project DeviceId, DeviceName, AcdTime=Timestamp,
    AcdFileName=FileName, AcdFolderPath=FolderPath,
    FileOriginUrl, FileOriginReferrerUrl, FileOriginIP, SHA1
);
let NovelRockwellWrites =
  DeviceFileEvents
  | where Timestamp >= ago(DetectionWindow)
  | where ActionType in~ ("FileCreated", "FileModified", "FileRenamed")
  | where InitiatingProcessVersionInfoCompanyName has "Rockwell"
    or InitiatingProcessVersionInfoProductName has "Studio 5000"
  | extend NormalizedFolder = tolower(FolderPath)
  | join kind=leftanti BaselinePaths on DeviceId, NormalizedFolder
  | project DeviceId, WriteTime=Timestamp, ActionType, FileName,
    FolderPath, InitiatingProcessFileName,
    InitiatingProcessCommandLine,
    InitiatingProcessVersionInfoCompanyName,
    InitiatingProcessVersionInfoProductName,
    InitiatingProcessAccountName, ReportId;

RecentAcd
| join kind=inner NovelRockwellWrites on DeviceId
| where WriteTime between (AcdTime - 5m .. AcdTime + 30m)
| project AcdTime, WriteTime, DeviceName, AcdFileName,
  AcdFolderPath, FileOriginUrl, FileOriginReferrerUrl,
  FileOriginIP, ActionType, FileName, FolderPath,
  InitiatingProcessFileName, InitiatingProcessCommandLine,
  InitiatingProcessVersionInfoCompanyName,
  InitiatingProcessVersionInfoProductName,
  InitiatingProcessAccountName, SHA1, ReportId
```

Condition	Purpose	Durability
Recent .ACD event	Provides project-related temporal context.	Medium
Rockwell attribution	Avoids treating every novel write as relevant.	Medium; schema dependent
Novel device folder	Compares the destination with 30-day device history.	Environment dependent
-5m to +30m	Allows imperfect project timing while retaining proximity.	Low until validated

Analyst Triage

Priority	Question	Evidence to collect
1	Was the ACD project newly downloaded or externally sourced?	Origin URL/referrer/IP, email/browser/USB timeline.
2	Did Studio 5000 actually access the project?	Process/file-handle telemetry, recent files and user confirmation.
3	What was written and where?	Destination path, hash, file type, signer and execution state.
4	Is the path legitimate for this engineering workflow?	Project owner, workstation role and approved output directories.

False-positive model

Scenario	Why it may match	Recommended handling
First use of a valid export path	A 30-day device baseline may not contain rare engineering folders.	Confirm project workflow and extend baseline if justified.
Software update or plugin	Rockwell components may write to new paths after change.	Correlate installation/change window and signer.
Project migration	Imported ACD projects may create new output locations.	Validate source, owner and expected generated files.

NO PREMATURE ALLOWLISTING

Do not allowlist a broad Rockwell process or engineering-workstation path. Record approved destination directories only after observing stable legitimate use and confirming ownership.

Validation Plan

Step	Action	Expected evidence
1	Profile Rockwell writes for 30-90 days.	Normal products, ActionTypes and destination folders.
2	Open a known-good ACD project in a lab.	Actual initiating process metadata and file-event coverage.
3	Test a controlled novel output path.	Whether the query forms the expected correlation.
4	Review every hit with an OT engineer.	Legitimate workflow vs unexplained write.
5	Decide whether promotion is supportable.	Stable telemetry and separable benign activity.

Decision	Criterion
Promote / retain	Rockwell metadata is reliable and unexplained novel writes are low-volume and investigable.
Tune	Replace broad company/product matching with the exact validated Studio 5000 process metadata.
Reject	ACD access is not observable, file events are incomplete, or normal projects write unpredictably across many folders.

OPERATING NOTE

Safety relevance is indirect: compromise of an engineering workstation could enable later controller access, but the advisory does not establish process manipulation in a specific environment.

ATT&CK; Mapping & References

Technique	Relationship	Mapping posture
T1203 - Exploitation for Client Execution	Opening a crafted project may trigger unsafe file writes and possible code execution.	Potential vulnerability outcome.
T1036 - Masquerading	A project file may appear legitimate to an engineer.	Possible delivery context, not required.

Primary and authoritative references

1. Rockwell Automation - Security Advisories, CVE-2026-9108
<https://www.rockwellautomation.com/en-us/trust-center/security-advisories.html>
2. Microsoft Learn - DeviceFileEvents schema
<https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-devicefileevents-table>
3. NVD - CVE-2026-9108
<https://nvd.nist.gov/vuln/detail/CVE-2026-9108>

DOCUMENT STATUS

Research-derived and unvalidated in the target environment. The package is suitable for controlled testing and analyst review; it is not evidence that a specific environment is compromised.